



Servicios Gestionados de Ciberseguridad

INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

Pruebas de intrusión sobre la infraestructura tecnológica
Cliente: Apex Gestoría

Referencia	JAMSEC-AUD-2026-001
Versión	1.0
Fecha	1 de junio de 2026
Autor	Alex Sánchez García — JAMSEC
Clasificación	CONFIDENCIAL

Documento confidencial. Su contenido no podrá ser divulgado a terceros sin autorización expresa de Apex Gestoría y JAMSEC.

Índice

Índice	2
1. Resumen ejecutivo.....	4
1.1. Cuadro de severidades.....	4
2. Alcance y objetivos	5
2.1. Activos en alcance.....	5
2.2. Objetivos	5
3. Metodología	6
3.1. Fases (PTES).....	6
3.2. Escala de severidad (CVSS v3.1).....	6
3.3. Herramientas utilizadas	6
4. Resumen de hallazgos.....	7
5. Hallazgos detallados	8
JAM-01 — Inyección SQL en el formulario de acceso (login.php)	8
Descripción	8
Evidencia	8
Impacto	8
Recomendación	8
JAM-02 — Base de datos MariaDB expuesta con superusuario remoto y contraseña débil	9
Descripción	9
Evidencia	9
Impacto	9
Recomendación	9
JAM-03 — Subida de ficheros sin validación (ejecución remota de código)	10
Descripción	10
Evidencia	10
Impacto	10
Recomendación	10
JAM-04 — Credenciales SSH débiles susceptibles de fuerza bruta	11
Descripción	11
Evidencia	11
Impacto	11
Recomendación	11
JAM-05 — Servidor FTP con acceso anónimo y exposición de información sensible	12
Descripción	12
Evidencia	12
Impacto	12

Recomendación	12
JAM-06 — Segmentación de red deficiente: la DMZ accede a la red interna (LAN)	13
Descripción	13
Evidencia	13
Impacto	13
Recomendación	13
JAM-07 — Almacenamiento de contraseñas en texto claro	14
Descripción	14
Evidencia	14
Impacto	14
Recomendación	14
JAM-08 — Comunicaciones sin cifrar (HTTP y FTP en texto claro)	15
Descripción	15
Evidencia	15
Impacto	15
Recomendación	15
JAM-09 — Interfaz de administración SSH del cortafuegos expuesta	16
Descripción	16
Evidencia	16
Impacto	16
Recomendación	16
6. Cadena de ataque	17
7. Detección y monitorización	18
8. Conclusiones y plan de remediación	19
9. Anexos	20

1. Resumen ejecutivo

JAMSEC ha realizado una auditoría de seguridad ofensiva (pruebas de intrusión) sobre la infraestructura tecnológica de Apex Gestoría. El objetivo fue evaluar la exposición real de los sistemas frente a un atacante externo y determinar el impacto sobre la información del negocio.

El resultado es desfavorable: se logró el compromiso total de la infraestructura del cliente, desde el acceso externo hasta la exfiltración de datos personales y financieros almacenados en la red interna. Se identificaron 9 hallazgos, de los cuales 3 son de severidad Crítica y 4 de severidad Alta.

La cadena de ataque combinó una inyección SQL en la aplicación web, la filtración de credenciales por un servicio FTP mal configurado y una segmentación de red deficiente, permitiendo el salto desde la zona desmilitarizada (DMZ) hasta la base de datos interna con privilegios de superusuario.

Se recomienda abordar de forma prioritaria los hallazgos críticos y altos conforme al plan de remediación del apartado 8.

1.1. Cuadro de severidades

Crítica	Alta	Media	Baja
3	4	2	0

2. Alcance y objetivos

El alcance de la auditoría comprende la infraestructura perimetral e interna de Apex Gestoría accesible a través de su punto de presencia en red (172.20.17.230) y los segmentos internos alcanzables tras un compromiso inicial.

2.1. Activos en alcance

Activo	Dirección	Función
apex-fw	172.20.17.230 (WAN)	Cortafuegos perimetral
apex-web	10.30.20.10 (DMZ)	Servidor web público
apex-db	10.30.10.10 (LAN)	Base de datos MariaDB
apex-srv	10.30.10.20 (LAN)	Servidor interno / FTP

2.2. Objetivos

- Identificar vulnerabilidades explotables en los servicios expuestos.
- Evaluar el impacto real mediante explotación controlada.
- Determinar la exposición de datos sensibles del cliente.
- Verificar la capacidad de detección y respuesta (SIEM/IDS).
- Proporcionar recomendaciones de remediación priorizadas.

3. Metodología

La auditoría siguió un enfoque de caja negra alineado con el marco PTES (Penetration Testing Execution Standard) y, para la parte web, con el OWASP Top 10 (2021) y la OWASP Testing Guide. La severidad de cada hallazgo se ha cuantificado con CVSS v3.1.

3.1. Fases (PTES)

- Recopilación de información y reconocimiento.
- Análisis de vulnerabilidades.
- Explotación.
- Post-explotación y movimiento lateral.
- Documentación e informe.

3.2. Escala de severidad (CVSS v3.1)

Severidad	Rango CVSS	Criterio de actuación
Crítica	9.0 – 10.0	Remediación inmediata
Alta	7.0 – 8.9	Remediación urgente (días)
Media	4.0 – 6.9	Remediación planificada
Baja	0.1 – 3.9	Remediación según disponibilidad

3.3. Herramientas utilizadas

nmap, sqlmap, hydra, whatweb, cliente FTP, cliente MariaDB, sshpass y utilidades estándar de red, ejecutadas desde la estación de auditoría de JAMSEC (Debian + arsenal de pentest).

4. Resumen de hallazgos

ID	Hallazgo	Severidad	CVSS
JAM-01	Inyección SQL en el formulario de acceso (login.php)	Crítica	9.8
JAM-02	Base de datos MariaDB expuesta con superusuario remoto y contraseña débil	Crítica	9.8
JAM-03	Subida de ficheros sin validación (ejecución remota de código)	Crítica	9.8
JAM-04	Credenciales SSH débiles susceptibles de fuerza bruta	Alta	8.8
JAM-05	Servidor FTP con acceso anónimo y exposición de información sensible	Alta	8.2
JAM-06	Segmentación de red deficiente: la DMZ accede a la red interna (LAN)	Alta	7.4
JAM-07	Almacenamiento de contraseñas en texto claro	Alta	7.5
JAM-08	Comunicaciones sin cifrar (HTTP y FTP en texto claro)	Media	5.9
JAM-09	Interfaz de administración SSH del cortafuegos expuesta	Media	5.3

5. Hallazgos detallados

JAM-01 — Inyección SQL en el formulario de acceso (login.php)

Severidad	Crítica (CVSS 9.8)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Categoría OWASP	A03:2021 – Injection
Activos afectados	apex-web (10.30.20.10) — http://172.20.17.230/login.php

Descripción

El parámetro 'usuario' del formulario de autenticación se concatena directamente en una consulta SQL sin parametrización ni saneamiento. Permite eludir la autenticación y, mediante consultas UNION/booleanas, extraer el contenido íntegro de la base de datos.

Evidencia

sqlmap identificó inyección boolean-based, time-based y UNION. Payload de bypass: usuario=admin' OR '1'='1. Se volcaron las tablas clientes, nominas y usuarios de la BBDD 'apexgestoria'. Evidencia: 03-sqlmap-dbs.txt, 04-sqlmap-dump.txt.

Impacto

Exposición total de datos personales y financieros (NIF, DNI, IBAN, salarios) de clientes y empleados, y de las credenciales de la aplicación. Incumplimiento del RGPD.

Recomendación

Usar consultas parametrizadas (prepared statements / PDO). Validar y normalizar toda entrada. Aplicar el principio de mínimo privilegio al usuario de BBDD de la aplicación. Desplegar un WAF como medida compensatoria.

JAM-02 — Base de datos MariaDB expuesta con superusuario remoto y contraseña débil

Severidad	Crítica (CVSS 9.8)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Categoría OWASP	A05:2021 – Security Misconfiguration
Activos afectados	apex-db (10.30.10.10:3306)

Descripción

El servicio MariaDB escucha en todas las interfaces (0.0.0.0) y permite la conexión del usuario root desde cualquier host ('root'@'%') con la contraseña trivial 'toor'. Cualquier sistema con alcance de red puede obtener control total de la base de datos.

Evidencia

Credenciales obtenidas del fichero credenciales.txt (ver JAM-05) y confirmadas durante el pivote: acceso root a la BBDD interna y exfiltración de la tabla de nóminas. Evidencia: 07-pivote.txt.

Impacto

Compromiso total de la confidencialidad, integridad y disponibilidad de todos los datos del cliente. Posibilidad de manipulación o destrucción de registros.

Recomendación

Vincular MariaDB a la interfaz interna (bind-address). Eliminar 'root'@'%'. Establecer contraseñas robustas y únicas. Restringir el acceso por IP de origen (solo el servidor de aplicación). Activar cifrado en tránsito.

JAM-03 — Subida de ficheros sin validación (ejecución remota de código)

Severidad	Crítica (CVSS 9.8)
Vector CVSS	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Categoría OWASP	A04:2021 – Insecure Design / A03 Injection
Activos afectados	apex-web (10.30.20.10) — panel.php

Descripción

El panel autenticado permite subir ficheros sin validar tipo, extensión ni contenido, almacenándolos en un directorio accesible desde la web (/uploads). Combinado con el bypass de autenticación (JAM-01), permite subir y ejecutar una webshell PHP (RCE).

Evidencia

Función `move_uploaded_file` sobre el nombre original sin comprobaciones; directorio /uploads con permisos de escritura (0777). Confirmada la viabilidad de webshell.

Impacto

Ejecución de comandos en el servidor web, sirviendo de punto de entrada al resto de la infraestructura (ver cadena de ataque).

Recomendación

Validar extensión/MIME mediante lista blanca, renombrar ficheros, almacenarlos fuera del directorio web y deshabilitar la ejecución de PHP en /uploads. Limitar tamaño y tipo.

JAM-04 — Credenciales SSH débiles susceptibles de fuerza bruta

Severidad	Alta (CVSS 8.8)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L
Categoría OWASP	A07:2021 – Identification and Authentication Failures
Activos afectados	apex-web (SSH publicado en 172.20.17.230:2222)

Descripción

El servidor SSH del servidor web está publicado en Internet y dispone de la cuenta 'soporte' con la contraseña adivinable 'soporte123', obtenida por ataque de diccionario.

Evidencia

hydra obtuvo: host 172.20.17.230, login soporte, password soporte123. Evidencia: 06-hydra-ssh.txt.

Impacto

Acceso interactivo al servidor de la DMZ con privilegios sudo, habilitando el movimiento lateral hacia la red interna.

Recomendación

Deshabilitar la autenticación por contraseña (solo clave pública). Política de contraseñas robustas. fail2ban / bloqueo por intentos. No publicar SSH en Internet; usar VPN/bastión.

JAM-05 — Servidor FTP con acceso anónimo y exposición de información sensible

Severidad	Alta (CVSS 8.2)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Categoría OWASP	A05:2021 – Security Misconfiguration
Activos afectados	apex-srv (FTP publicado en 172.20.17.230:21)

Descripción

El servicio vsftpd permite acceso anónimo con permisos de lectura y escritura, exponiendo ficheros con credenciales internas y un volcado de base de datos.

Evidencia

Descarga anónima de credenciales.txt (contiene root/toor de la BBDD, credenciales de la app y del router) y de backup_apexgestoria.sql. Evidencia: 05-ftp.txt, ftp-credenciales.txt.

Impacto

Filtración de credenciales que habilitan los hallazgos JAM-02 y la cadena de ataque completa. La escritura anónima permite alojar contenido malicioso.

Recomendación

Deshabilitar el acceso anónimo. Eliminar ficheros sensibles del servicio. Forzar FTPS/SFTP. Restringir por IP y aplicar mínimo privilegio.

JAM-06 — Segmentación de red deficiente: la DMZ accede a la red interna (LAN)

Severidad	Alta (CVSS 7.4)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
Categoría OWASP	A01:2021 – Broken Access Control
Activos afectados	apex-fw (política de cortafuegos)

Descripción

El cortafuegos perimetral permite tráfico sin restricción desde el segmento DMZ hacia la LAN interna. Un servidor de la DMZ comprometido puede alcanzar directamente la base de datos y el servidor interno.

Evidencia

Desde apex-web (DMZ) se alcanzaron 10.30.10.10:3306 y 10.30.10.20:21 (LAN). Evidencia: 07-pivote.txt.

Impacto

Anula el propósito de la DMZ: convierte un compromiso perimetral en acceso a los datos internos (movimiento lateral).

Recomendación

Aplicar microsegmentación: permitir desde la DMZ únicamente los puertos estrictamente necesarios (p.ej. la app web hacia la BBDD en 3306) y denegar el resto por defecto.

JAM-07 — Almacenamiento de contraseñas en texto claro

Severidad	Alta (CVSS 7.5)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Categoría OWASP	A02:2021 – Cryptographic Failures
Activos afectados	apex-db — tabla apexgestoria.usuarios

Descripción

Las contraseñas de los usuarios de la aplicación se almacenan sin cifrar ni aplicar funciones hash, visibles directamente al consultar la base de datos.

Evidencia

Volcado de la tabla usuarios: admin/Apex.2026!, jmorales/gestoria2024, soporte/soporte123.
Evidencia: 04-sqlmap-dump.txt.

Impacto

Cualquier acceso a la BBDD revela credenciales reutilizables en otros servicios.

Recomendación

Almacenar contraseñas con un algoritmo de hash robusto y salado (bcrypt/Argon2). Forzar el restablecimiento de todas las contraseñas afectadas.

JAM-08 — Comunicaciones sin cifrar (HTTP y FTP en texto claro)

Severidad	Media (CVSS 5.9)
Vector CVSS	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Categoría OWASP	A02:2021 – Cryptographic Failures
Activos afectados	apex-web (HTTP/80), apex-srv (FTP/21)

Descripción

Las aplicaciones web y de transferencia de ficheros operan sin TLS, transmitiendo credenciales y datos sensibles en texto claro.

Evidencia

Servicio web solo en el puerto 80 (443 cerrado); vsftpd sin TLS. Evidencia: 01-nmap-servicios.txt.

Impacto

Interceptación de credenciales y datos mediante ataques de interceptación (MITM) en la red.

Recomendación

Implantar HTTPS con certificados válidos y redirección forzada. Habilitar FTPS o sustituir por SFTP. Aplicar HSTS.

JAM-09 — Interfaz de administración SSH del cortafuegos expuesta

Severidad	Media (CVSS 5.3)
Vector CVSS	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Categoría OWASP	A05:2021 – Security Misconfiguration
Activos afectados	apex-fw (172.20.17.230:22)

Descripción

El servicio SSH de gestión del cortafuegos perimetral es accesible desde la red de tránsito, ampliando la superficie de ataque del dispositivo de seguridad.

Evidencia

nmap detectó 22/tcp abierto en el perímetro. Evidencia: 01-nmap-servicios.txt.

Impacto

Posibilidad de ataques de fuerza bruta o explotación contra el propio cortafuegos.

Recomendación

Restringir la gestión a una red de administración dedicada o VPN. Autenticación por clave y MFA. Filtrado por IP de origen.

6. Cadena de ataque

La explotación encadenada de los hallazgos permitió pasar de un acceso externo nulo al control de la base de datos interna:

- Reconocimiento: descubrimiento de los servicios publicados (web, SSH, FTP) en el perímetro.
- Acceso a credenciales: descarga anónima por FTP del fichero de credenciales internas (JAM-05).
- Compromiso web: inyección SQL en el login y volcado de la base de datos (JAM-01).
- Acceso interactivo: fuerza bruta del usuario SSH 'soporte' en el servidor web (JAM-04).
- Movimiento lateral: desde la DMZ se alcanza la LAN interna por la segmentación deficiente (JAM-06).
- Exfiltración: acceso root a MariaDB con las credenciales filtradas y robo de las nóminas (JAM-02).

7. Detección y monitorización

La infraestructura de monitorización de JAMSEC (SIEM Wazuh + IDS Suricata) registró actividad asociada a la auditoría, demostrando capacidad de detección:

- Suricata (IDS de red): detección de escaneo de puertos ('ET SCAN Possible Nmap User-Agent').
- Wazuh (HIDS): múltiples 'sshd: authentication failed' (fuerza bruta) y posterior 'authentication success' (acceso).
- Wazuh: 'vsftpd: FTP Authentication success' (acceso anónimo al FTP).
- Wazuh: 'Web server 500 error' recurrentes durante el sondeo de inyección SQL.

Recomendación: definir reglas de correlación y alertado proactivo (notificación) para estos patrones, y considerar el modo de prevención en línea (IPS) en el perímetro.

8. Conclusiones y plan de remediación

El nivel de seguridad de la infraestructura auditada es insuficiente. La combinación de errores de configuración, validación de entrada y segmentación permite un compromiso total con bajo nivel de esfuerzo. Se propone el siguiente plan priorizado:

Prioridad	Acción	Hallazgos
Inmediata	Parametrizar consultas SQL y desplegar WAF; restablecer credenciales	JAM-01, JAM-07
Inmediata	Restringir MariaDB a la LAN y eliminar root remoto con contraseña débil	JAM-02
Inmediata	Corregir la subida de ficheros y bloquear ejecución en /uploads	JAM-03
Urgente	Endurecer SSH (solo clave, fail2ban) y retirar de Internet	JAM-04, JAM-09
Urgente	Deshabilitar FTP anónimo y retirar ficheros sensibles	JAM-05
Urgente	Microsegmentar DMZ↔LAN en el cortafuegos	JAM-06
Planificada	Implantar HTTPS/FTPS en todos los servicios	JAM-08

9. Anexos

Las evidencias completas (salidas de nmap, sqlmap, hydra, FTP y del pivote) se adjuntan en el directorio de evidencias del repositorio del proyecto:

- 01-nmap-servicios.txt — reconocimiento de servicios.
- 03-sqlmap-dbs.txt / 04-sqlmap-dump.txt — inyección SQL y volcado de datos.
- 05-ftp.txt / ftp-credenciales.txt / ftp-backup.sql — acceso FTP anónimo.
- 06-hydra-ssh.txt — fuerza bruta SSH.
- 07-pivote.txt — movimiento lateral DMZ→LAN y exfiltración.